

Data Breach Notification Procedure

Company A
Ministry of Health - Kingdom of Saudi Arabia

Document Control

Field	Details
Document Title	Data Breach Notification Procedure
Document ID	PDP-BREACH-004
Version	2.7
Effective Date	August 12, 2024
Last Review Date	August 5, 2024
Next Review Date	August 12, 2025
Classification	INTERNAL - RESTRICTED
Legal Basis	KSA Personal Data Protection Law (PDPL) - Royal De
Related NDMO Controls	Domain 6: Personal Data Protection - Controls 6.12
Owner	Chief Privacy Officer (CPO)
Approver	Legal & Privacy Office

Version History

Version	Date	Author	Changes
1.0	March 2022	Noura Al-Mansour (DPO)	Initial procedure post-PDPL enactment
2.0	September 2022	Noura Al-Mansour	Added risk assessment matrix
2.3	March 2023	Khalid Al-Otaibi (CPO)	Updated SDAIA notification process
2.5	November 2023	Khalid Al-Otaibi	Added data subject notification templates
2.7	August 2024	Khalid Al-Otaibi	Added breach simulation testing requirements

Table of Contents

1. [Purpose and Scope](#1-purpose-and-scope)
2. [Legal Requirements](#2-legal-requirements)
3. [Definitions](#3-definitions)
4. [Breach Risk Assessment](#4-breach-risk-assessment)
5. [Notification to Regulator (SDAIA)](#5-notification-to-regulator-sdaia)
6. [Notification to Data Subjects](#6-notification-to-data-subjects)
7. [Roles and Responsibilities](#7-roles-and-responsibilities)
8. [Breach Notification Process Flow](#8-breach-notification-process-flow)
9. [Notification Templates](#9-notification-templates)
10. [Escalation Matrix](#10-escalation-matrix)
11. [Testing and Training](#11-testing-and-training)
12. [Metrics and KPIs](#12-metrics-and-kpis)
13. [Appendices](#13-appendices)

1. Purpose and Scope

1.1 Purpose

This procedure establishes the mandatory process for notifying relevant parties when a personal data breach occurs at Company A. It ensures compliance with:

- KSA Personal Data Protection Law (PDPL) - Article 21 (Breach Notification)
- SDAIA Breach Notification Guidelines (v2.1, issued June 2023)
- NDMO Controls 6.12-6.14 (Personal Data Breach Management)

1.2 Scope

Applies To:

- All personal data breaches involving Saudi citizens or residents
- All departments and staff at Company A (850 employees)
- All third-party data processors acting on Company A's behalf

Covers:

- Risk assessment methodology to determine notification requirements
- Notification procedures to SDAIA (Saudi Data & Artificial Intelligence Authority)
- Notification procedures to affected data subjects (patients, employees)
- Documentation and record-keeping requirements

Exclusions:

- Non-personal data breaches (covered by Security_Incident_Response_Plan_v3.0)
- Breaches that do NOT involve personal data as defined by PDPL

1.3 Relationship to Other Documents

This procedure is a specialized subset of:

- Security_Incident_Response_Plan_v3.0.pdf.md (general incident response)
- Privacy_Policy_v5.1.pdf.md (public-facing privacy commitments)

Key Difference: This procedure focuses ONLY on breaches involving personal data requiring regulatory notification.

2. Legal Requirements

2.1 PDPL Article 21: Breach Notification Obligation

Article 21 (Paraphrased):

> "The Data Controller must notify the competent authority (SDAIA) within 72 hours of becoming aware of a personal data breach that is likely to result in a risk to the rights and freedoms of natural persons."

Key Elements:

1. Clock Starts: When Company A becomes aware (not when breach occurred)
2. Timeline: 72 hours maximum
3. Threshold: Only if breach poses "risk to rights and freedoms" (determined via risk assessment)
4. Data Subject Notification: Required if breach poses "high risk" (more stringent threshold)

2.2 SDAIA Breach Notification Portal

Official Portal: <https://sdaia.gov.sa/breach-notification> (simulated URL)

Portal Features:

- Online breach notification form (Arabic/English)
- Secure file upload for incident reports
- Case tracking number issued upon submission
- Follow-up communication channel

Authentication: Requires Nafath (national digital identity) for CPO or designated representative

2.3 Penalties for Non-Compliance

PDPL Article 27 - Administrative Penalties:

Violation	Penalty (SAR)	Notes
Failure to notify SDAIA within 72 hours	Up to 5,000,000 SAR	Per SDAIA enforcement guidelines
Failure to notify data subjects when required	Up to 3,000,000 SAR	If breach posed high risk
Providing false/misleading information	Up to 10,000,000 SAR	Criminal liability possible

Reputational Risk: Beyond financial penalties, breach mishandling damages public trust in healthcare system.

3. Definitions

Term	Definition
Personal Data Breach	A breach of security leading to the accidental or
Personal Data	Any information relating to an identified or ident
Data Subject	The individual (patient, employee, visitor) to who
Becoming Aware	When Company A has a reasonable degree of certain
Rights and Freedoms	Fundamental rights such as confidentiality, privac
High Risk	Breach likely to result in significant adverse eff
Competent Authority	SDAIA (Saudi Data & Artificial Intelligence Author

4. Breach Risk Assessment

4.1 The Two-Tier Risk Model

Company A uses a two-tier risk assessment to determine notification obligations:

1. Tier 1 - Risk Assessment: Does the breach pose a risk to data subjects?
 - YES → Notify SDAIA within 72 hours
 - NO → Document internally, no notification required
2. Tier 2 - High Risk Assessment: Does the breach pose a high risk to data subjects?
 - YES → Also notify affected data subjects without undue delay
 - NO → SDAIA notification only

4.2 Risk Assessment Factors (SDAIA Guidelines)

The CPO considers the following factors when assessing breach severity:

Factor	Low Risk Example	High Risk Example
Volume of Data	<100 individuals	>10,000 individuals
Sensitivity of Data	General contact info (name, email)	Health records, national IDs, financial data
Ease of Identification	Pseudonymized data	Data with clear identifiers (name + ID)
Severity of Consequences	Inconvenience, spam emails	Identity theft, medical harm, blackmail
Special Categories	Regular personal data	Health data, biometrics, criminal records
Data Subject Vulnerabilities	General adult population	Children, elderly, patients with mental illness

Technical Safeguards	Data encrypted at rest and in transit	Unencrypted data stolen
Incident Duration	Detected and contained within 1 hour	Ongoing for weeks before detection

4.3 Risk Assessment Matrix

Quick Reference Matrix:

Data Type	Affected Individuals	Safeguards	Risk Level	Notify SDAIA?	Notify Subjects?
Contact info (name, phone)<100		Encrypted	LOW	■ No	■ No
Contact info (name, phone)>1,000		Unencrypted	MEDIUM	■ Yes	■ No
Medical records	Any number	Encrypted	HIGH	■ Yes	■ Yes
Medical records	Any number	Unencrypted	CRITICAL	■ Yes	■ Yes (urgent)
National ID numbers	>100	Unencrypted	HIGH	■ Yes	■ Yes
Employee HR files	<50	Encrypted	MEDIUM	■ Yes	■ No

Decision Rule: When in doubt, escalate to CPO for final determination. Err on the side of notification.

4.4 Risk Assessment Documentation

Form: Breach Risk Assessment Form (see Appendix A)

Required for EVERY breach (even if no notification required):

- Description of breach (what, when, how)
- Data types involved
- Number of affected individuals
- Risk factors analysis
- Conclusion: Risk level (Low/Medium/High/Critical)
- Decision: Notify SDAIA? Notify subjects?
- Approver: CPO signature

Retention: 7 years (per PDPL retention requirements)

5. Notification to Regulator (SDAIA)

5.1 Notification Timeline

Mandatory Deadline: 72 hours from when Company A becomes aware of the breach

Clock Start Example:

- Tuesday 10:00 AM: SOC detects ransomware encryption on file server
- Tuesday 11:30 AM: Incident Response Team confirms patient data affected (Company A "becomes aware")

- Clock Starts: Tuesday 11:30 AM
- Notification Deadline: Friday 11:30 AM (72 hours later)

Note: 72-hour clock runs continuously (includes nights and weekends).

5.2 Notification Content Requirements

The notification to SDAIA must include (per SDAIA guidelines v2.1):

1. Nature of the Personal Data Breach

- Type of breach (unauthorized access, accidental disclosure, data loss, cyberattack)
- Date and time breach occurred (if known) and when Company A became aware
- Description of how breach happened

2. Categories and Approximate Number of Data Subjects Concerned

- E.g., "Approximately 12,000 patients" or "47 employees"

3. Categories and Approximate Number of Personal Data Records Concerned

- E.g., "15,000 medical consultation records" or "82 employee personnel files"

4. Likely Consequences of the Breach

- Potential harm to data subjects (identity theft risk, medical information exposure, etc.)
- Business impact (system downtime, reputational damage)

5. Measures Taken or Proposed to Address the Breach

- Immediate containment actions
- Remediation steps completed
- Planned future mitigations

6. Contact Details of Data Protection Officer (DPO)

- Name: Noura Al-Mansour
- Email: dpo@companya.gov.sa
- Phone: +966-11-XXX-XXXX

7. Supporting Documentation (attach to portal submission)

- Breach Risk Assessment Form
- Incident timeline
- Forensic analysis (if available)

5.3 Notification Submission Process

Step-by-Step:

1. CPO Drafts Notification: Using template (see Section 9.1) within 48 hours of breach awareness
2. Legal Review: Legal Counsel reviews draft for accuracy and legal privilege considerations (4 hours)
3. Executive Approval: CEO or designee approves notification (2 hours)
4. Portal Submission: CPO logs into SDAIA portal via Nafath and submits notification
5. Case Number: SDAIA issues tracking number (e.g., BR-2024-KSA-00123)

6. Confirmation Email: SDAIA sends acknowledgment within 24 hours

7. Follow-Up: SDAIA may request additional information (Company A must respond within 48 hours)

Total Process Time: Target 60 hours (leaves 12-hour buffer before 72-hour deadline)

5.4 Phased Notification (If Information Incomplete)

PDPL Allowance: If full information is not available within 72 hours, Company A may submit phased notification:

- Initial Notification (within 72 hours): Submit what is known, flag incomplete sections
- Supplemental Notification (as soon as available): Update SDAIA portal with additional details

Example: If forensic analysis of breach scope takes 5 days, submit initial notification with "Investigation ongoing, exact number of affected subjects under review" and update when confirmed.

6. Notification to Data Subjects

6.1 Notification Requirement

Trigger: Breach poses high risk to rights and freedoms of data subjects (per Section 4 risk assessment)

Timeline: Without undue delay (PDPL does not specify exact hours, but best practice: within 7 days of becoming aware)

Exemptions (no data subject notification required):

- ■ Encrypted Data: Data was encrypted with strong encryption (AES-256) and key not compromised
- ■ Subsequent Measures: Company A took measures ensuring high risk no longer materializes (e.g., attacker arrested, data recovered)
- ■ Disproportionate Effort: Notification would require disproportionate effort (e.g., 500,000 subjects, unknown addresses) → Public notice instead

6.2 Notification Content (To Data Subjects)

The notification must be in clear and plain language (Arabic for Saudi subjects, English option available):

Required Elements:

1. Description of breach: What happened in non-technical terms
2. Categories of data affected: E.g., "Your medical consultation notes from 2023-2024"
3. Likely consequences: What harm could result (e.g., "Your health information may be publicly available")
4. Measures taken: What Company A has done to fix the breach
5. Recommended actions: What data subject should do (e.g., "Monitor your bank statements," "Change your password")
6. Contact point: How to reach Company A for questions (DPO contact details)

Must NOT include:

- Technical jargon (e.g., "SQL injection vulnerability in Epic EHR")
- Blame or finger-pointing

- Promises Company A cannot keep (e.g., "This will never happen again")

6.3 Notification Channels

Preferred Method: Direct communication (email or SMS to individual data subjects)

Alternative Methods (if direct notification impossible or disproportionate):

- Public Notice: Posted on Company A website (www.companya.gov.sa)
- Press Release: Issued to major Saudi media outlets (Saudi Press Agency, Al-Arabiya)
- Social Media: Posted on Company A official Twitter/X account (@CompanyA_KSA)

2024 Notification Statistics:

- Breaches Requiring Subject Notification: 2
- Incident 1 (March 2024): 324 patients notified via email (unauthorized access to appointment records)
- Incident 2 (July 2024): 12,000 patients notified via SMS + public notice (ransomware affecting Epic EHR backup)

6.4 Notification Template

See Section 9.2 for full data subject notification letter template (Arabic + English versions).

7. Roles and Responsibilities

7.1 Breach Notification RACI Matrix

Task	CPO	DPO	CISO	Legal	Communications	CEO
Detect breach	I	I	R	I	I	I
Assess if personal data involved	I	A	C	I	I	I
Perform risk assessment	R	A	C	C	I	I
Draft SDAIA notification	R	C	C	A	I	I
Submit to SDAIA portal	R	I	I	C	I	A
Draft data subject notification	C	R	I	A	C	I
Send data subject notification	I	I	I	C	R	A
Document breach in register	I	A	I	I	I	I

Legend: R = Responsible (does the work), A = Accountable (approves), C = Consulted, I = Informed

7.2 Key Roles

Chief Privacy Officer (CPO) - Khalid Al-Otaibi

- Primary Role: Leads breach notification process

YES ■ NO → Handled by Security Incident Response Plan v3.0

■ (Stop: Not a PDPL breach)

[illegible]

■ 3. RISK ASSESSMENT ■ (CPO: Use Section 4 matrix)

■ - Data sensitivity ■

■ - # of subjects ■

■ - Safeguards ■

[illegible]

■ 4. DETERMINE NOTIFICATION REQUIRED ■

■ - Low Risk: Document only ■

■ - Medium/High: Notify SDAIA ■

■ - High Risk: Also notify subjects ■

[illegible]

■ 5. DRAFT SDAIA ■ (CPO drafts, Legal reviews)

■ NOTIFICATION ■ (Within 48 hours)

■ (72-hour clock) ■

[illegible]

XXXXXXXXXXXXXXXXXXXXXXXXXXXX

■ 6. EXECUTIVE ■ (CEO or delegate approves)

■ APPROVAL ■ (Within 60 hours)

[illegible]

■



XXXXXXXXXXXXXXXXXXXXXXXXXXXX

■ 7. SUBMIT TO SDAIA ■ (CPO via Nafath login)

■ PORTAL ■ (Before 72-hour deadline)

[illegible]

■ 8. DATA SUBJECT ■ (If high risk determination)

■ NOTIFICATION ■ (Communications team sends)

■ (if required) ■ (Within 7 days)

[illegible]

■



XXXXXXXXXXXXXXXXXXXXXXXXXXXX

[illegible]

Date/Time Breach Occurred: [Insert date/time or "Under investigation"]
Date/Time Company A Became Aware: [Insert exact timestamp]
Date/Time of This Notification: [Auto-populated by portal]

Nature of Breach (select all that apply):

- ☐ Unauthorized access by external party (cyberattack)
- ☐ Unauthorized access by internal employee
- ☐ Accidental disclosure (e.g., email to wrong recipient)
- ☐ Loss or theft of physical records/devices
- ☐ Ransomware or malware
- ☐ [Other - specify]: _____

Description of Breach:

[Detailed narrative: What happened? How did it happen? What systems were affected?]

SECTION 3: AFFECTED DATA

Categories of Data Subjects:

- ☐ Patients/Customers
- ☐ Employees
- ☐ Children (<18 years)
- ☐ Contractors/Suppliers
- ☐ [Other]: _____

Approximate Number of Affected Data Subjects: _____ individuals

Categories of Personal Data Affected (select all that apply):

- ☐ Identification data (name, national ID, passport)
- ☐ Contact details (phone, email, address)
- ☐ Health/medical records
- ☐ Financial information (bank accounts, credit cards)
- ☐ Biometric data (fingerprints, facial recognition)
- ☐ Location data
- ☐ Sensitive data (race, religion, political opinions, criminal records)
- ☐ [Other]: _____

Approximate Number of Affected Records: _____ records

SECTION 4: CONSEQUENCES

Likely Consequences to Data Subjects:

[Describe potential harm: identity theft risk, medical privacy compromise, financial fraud, etc.]

SECTION 5: MITIGATION MEASURES

Measures Taken to Contain the Breach:

1. [E.g., Isolated affected systems from network]
2. [E.g., Changed all administrator passwords]
3. [E.g., Engaged external forensic investigator]

Measures Taken or Proposed to Mitigate Adverse Effects:

1. [E.g., Notified affected data subjects]

2. [E.g., Offered free credit monitoring service for 2 years]
3. [E.g., Enhanced encryption on all patient databases]

SECTION 6: DATA SUBJECT NOTIFICATION

Have data subjects been notified?

- Yes (attach copy of notification letter)
- No - Notification not required (low risk)
- No - Notification planned for [insert date]
- No - Disproportionate effort (public notice will be issued)

SECTION 7: DATA PROTECTION OFFICER (DPO) CONTACT

DPO Name: Noura Al-Mansour

DPO Email: dpo@companya.gov.sa

DPO Phone: +966-11-XXX-XXXX

SECTION 8: ATTACHMENTS

- Breach Risk Assessment Form
- Incident timeline
- Forensic analysis report (if available)
- Data subject notification letter (if applicable)
- [Other]:

[REDACTED]

DECLARATION

I confirm that the information provided in this notification is accurate and complete to the best of my knowledge as of the date of submission.

Name: Khalid Al-Otaibi

Title: Chief Privacy Officer

Date: [Insert date]

Signature: [Digital signature via Nafath]

[illegible]

9.2 Data Subject Notification Template (English)

[Email/SMS to Affected Individuals]

IMPORTANT NOTICE: DATA BREACH NOTIFICATION

Company A - Ministry of Health

[illegible]

Dear [Patient Name / Employee Name],

We are writing to inform you of a data security incident that may have affected your personal information held by Company A.

WHAT HAPPENED

On [Date], we discovered that [brief description of breach in plain language, e.g., "an unauthorized individual gained access to our patient appointment database"]. We immediately launched an investigation and took steps to secure our systems.

WHAT INFORMATION WAS INVOLVED

The incident may have exposed the following information about you:

- [E.g., Full name]
- [E.g., National ID number]
- [E.g., Medical consultation records from 2023-2024]
- [E.g., Contact information (phone number, email address)]

WHAT WE ARE DOING

We have:

- Secured the affected systems and closed the security vulnerability
- Engaged a leading cybersecurity firm to conduct a forensic investigation
- Notified the Saudi Data & Artificial Intelligence Authority (SDAIA)
- Enhanced our security monitoring to prevent similar incidents

WHAT WE RECOMMEND YOU DO

To protect yourself, we recommend you:

1. Monitor your bank statements and credit reports for unusual activity
2. Be cautious of phishing emails or phone calls claiming to be from Company A
3. [If applicable] Change your password for your online patient portal
4. [If applicable] Contact your bank to place a fraud alert on your accounts

ADDITIONAL SUPPORT

We take this incident very seriously and sincerely apologize for any concern it may cause.

If you have questions or would like more information, please contact our Data Protection Officer:

Noura Al-Mansour, Data Protection Officer

Email: dpo@companya.gov.sa

Phone: +966-11-XXX-XXXX (Hotline: Monday-Sunday, 8 AM - 8 PM)

Sincerely,

Dr. Abdullah Al-Fahad

Chief Executive Officer

Company A

This notification is provided in compliance with the KSA Personal Data Protection Law (PDPL).

Arabic Version: [Equivalent template provided in Arabic for Saudi nationals]

10. Escalation Matrix

10.1 Escalation Triggers

Scenario	Escalate To	Timeframe	Action
Breach affects >10,000 patients	CEO	Immediate	CEO must approve all communications
Breach involves children's data	CEO + Legal	Within 1 hour	Heightened notification requirements
Ransomware with ransom demand	CEO + Board	Within 2 hours	Board must approve any payment decisions
Media inquiries received	CEO + Communications	Immediate	All media inquiries routed to Communications Director
SDAIA requests investigation meeting	CEO + CPO + Legal	Within 4 hours	Legal prepares briefing materials
Class action lawsuit filed	CEO + Legal	Immediate	Legal engages external litigation counsel
Breach caused by insider threat (employee)	CEO + HR + Legal	Within 2 hours	HR initiates disciplinary investigation
Breach crosses 72-hour deadline	CEO + Legal + Board	Immediate	Legal prepares penalty mitigation strategy

10.2 Communication Protocols

Media Inquiries:

- All inquiries forwarded to Communications Director (Sara Al-Mutairi)
- Holding statement available within 2 hours of public breach disclosure
- No individual employees authorized to speak to media (only CEO/Communications Director)

SDAIA Inquiries:

- All inquiries routed to CPO (Khalid Al-Otaibi) or DPO (Noura Al-Mansour)
- Response SLA: 48 hours for written requests, 24 hours for urgent verbal requests

11. Testing and Training

11.1 Breach Notification Simulation (Tabletop Exercise)

Frequency: Twice per year (Q2 and Q4)

Participants: CPO, DPO, CISO, Legal, Communications, CEO

Scenario Examples:

- Scenario 1: Ransomware encrypts Epic EHR backup with 50,000 patient records
- Scenario 2: Employee accidentally emails patient list to external researcher
- Scenario 3: Stolen laptop contains unencrypted employee HR files

Exercise Objectives:

- Practice 72-hour notification timeline
- Test SDAIA portal submission process
- Draft sample notifications

- Identify process gaps

2024 Exercises Conducted:

- Q2 2024 (May 15): Ransomware scenario (6 participants, 90 minutes)
- Finding: Notification template outdated (updated post-exercise)
- Q4 2024 (November 20): Planned

11.2 Staff Awareness Training

Target Audience: All Company A staff (850 employees)

Training Content:

- How to recognize a personal data breach
- Reporting procedure (call SOC hotline: +966-11-XXX-XXXX)
- Do's and Don'ts (e.g., "Don't post about breach on social media")

Delivery Method:

- Annual mandatory e-learning (30 minutes)
- Phishing simulation (quarterly) to test breach detection skills

2024 Training Statistics:

- Completion Rate: 97% (target: 95%) ■
- Average Quiz Score: 88% (target: 80%) ■

12. Metrics and KPIs

12.1 Breach Notification Performance Metrics

Tracked Quarterly by CPO:

Metric	Target	Q1 2024	Q2 2024	Q3 2024	Q4 2024
Breaches requiring SDAIA notification	0	0	1	1	0
SDAIA notifications submitted 100% within 72 hours	N/A	N/A	100% ■	100% ■	N/A
Average notification submission time 50 hours	N/A	N/A	58 hours ■	48 hours ■	N/A
Data subject notifications sent 100% within 7 days	N/A	N/A	100% ■	100% ■	N/A
SDAIA follow-up requests responded to on time	N/A	N/A	100% ■	100% ■	N/A
Regulatory penalties incurred 0 SAR	0 ■	0 ■	0 ■	0 ■	0 ■

12.2 Annual Breach Statistics Report

Submitted to: Data Governance Committee (DGC), Board Audit & Risk Committee

Contents:

- Total personal data breaches (all risk levels)
- Breaches requiring SDAIA notification
- Breaches requiring data subject notification
- Root cause analysis (technical failures vs. human error)
- Lessons learned and process improvements

2023 Annual Report Summary:

- Total Breaches: 5 (3 low risk, 2 high risk)
- SDAIA Notifications: 2
- Data Subject Notifications: 2 (total 12,324 individuals notified)
- Root Causes: 3 cyberattacks, 2 employee errors
- Regulatory Penalties: 0 SAR ■

13. Appendices

Appendix A: Breach Risk Assessment Form

[Form to be completed by CPO for every breach]

Breach Reference Number: BR-2024-_____

Date of Assessment: _____

Assessor Name: _____

SECTION 1: BREACH DESCRIPTION

- What happened? _____
- When did breach occur? _____
- When did Company A become aware? _____
- How was breach detected? _____

SECTION 2: DATA ASSESSMENT

- Data types involved: ■ Contact info ■ National IDs ■ Health records ■ Financial ■ Biometric ■ Other: _____
- Number of affected individuals: _____
- Special categories (children, vulnerable populations): ■ Yes ■ No

SECTION 3: RISK FACTORS

- Data encrypted? ■ Yes ■ No
- Breach contained? ■ Yes (within ____ hours) ■ No (ongoing)
- Attacker identified? ■ Yes ■ No ■ N/A (not malicious)

SECTION 4: RISK DETERMINATION

- LOW RISK: Document internally, no notification required
- MEDIUM RISK: Notify SDAIA only
- HIGH RISK: Notify SDAIA + data subjects
- CRITICAL RISK: Notify SDAIA + data subjects (urgent) + escalate to CEO

SECTION 5: NOTIFICATION DECISION

- Notify SDAIA? ☐ Yes (by _____) ☐ No
- Notify data subjects? ☐ Yes (by _____) ☐ No
- Rationale: _____

SECTION 6: APPROVAL

CPO Signature: _____

Date: _____

Appendix B: Breach Register (Extract)

[Maintained by DPO - Full register stored in SharePoint: Compliance/PDPL/Breach_Register_2024.xlsx]

Breach ID	Date Occurred	Date Aware	Data Type	# Subjects	Risk Level	SDAIA Notified	Subjects Notified	Status
BR-2024-001	Jan 15, 2024	Jan 15, 2024	Contact info	45	Low	☐ No	☐ No	Closed
BR-2024-002	Mar 10, 2024	Mar 11, 2024	Appointment records	184	Medium	☐ Yes (Mar 13)	☐ Yes (Mar 15)	Closed
BR-2024-003	May 3, 2024	May 3, 2024	HR files	12	Low	☐ No	☐ No	Closed
BR-2024-004	Jul 22, 2024	Jul 22, 2024	Medical records	12,000	High	☐ Yes (Jul 24)	☐ Yes (Jul 26)	Under review

Retention: All breach records retained for 7 years per PDPL requirements.

Appendix C: Quick Reference Checklist

☐ ☐ WHEN A BREACH IS DETECTED:

Within 2 Hours:

- ☐ Notify CPO (Khalid Al-Otaibi): +966-50-123-4567
- ☐ CPO determines if personal data involved (if NO → stop here, follow Security_Incident_Response_Plan)
- ☐ CPO documents "becoming aware" timestamp (starts 72-hour clock)

Within 4 Hours:

- ☐ CPO completes Breach Risk Assessment Form (Appendix A)
- ☐ CPO determines: Notify SDAIA? Notify subjects?

Within 48 Hours:

- ☐ CPO drafts SDAIA notification (use template Section 9.1)
- ☐ Legal Counsel reviews notification

Within 60 Hours:

- ☐ CEO approves notification
- ☐ CPO prepares to submit via SDAIA portal

Within 72 Hours:

- ■ CPO submits notification to SDAIA (login via Nafath)
- ■ Save SDAIA case tracking number

Within 7 Days:

- ■ Communications team sends data subject notifications (if required)

Within 10 Days:

- ■ DPO updates Breach Register (Appendix B)

Document Approval:

Prepared By:

Khalid Al-Otaibi, Chief Privacy Officer

Date: August 5, 2024

Reviewed By:

Noura Al-Mansour, Data Protection Officer

Layla Al-Harbi, Legal Counsel

Date: August 8, 2024

Approved By:

Dr. Abdullah Al-Fahad, Chief Executive Officer

Date: August 12, 2024

Next Review Date: August 12, 2025

Document Location: SharePoint → Compliance → PDPL → Data_Breach_Notification_Procedure_v2.7

END OF DOCUMENT